EXECUTIVE SUMMARY

Contain AI-speed attacks automatically, in 90 days

DECISION Approve automated containment on low-risk targets. Sign policy by day 30.

Risk reduction

RISK	TODAY*	DAY 30	DAY 60	DAY 90	WHAT MOVES IT
Ransomware spreads before we act	🔴	🟡	🟡	🟢	Decoys, auto-isolate on credential theft and ransomware prep
Phishing / malware on a laptop	🟡	🟡	🟡	🟢	EDR block mode, auto-contain, AI triage on every alert
Stolen passwords, MFA abuse	🔴	🔴	🟡	🟡	Admin phishing-resistant MFA, auto sign-out + reset
Exploited VPN, firewall, web app	🔴	🟡	🟡	🟡	Admin pages off internet, 72 h patching, change alerts
Cloud account takeover (Azure, AWS)	🔴	🔴	🔴	🟡	Auto-restore logging, cut off stolen cloud keys
Attacker blinds our tools	🔴	🟡	🟢	🟢	Log health alerts, EDR tamper detection
Our AI agents hijacked	🔴	🔴	🔴	🔴	Inventory at day 90; kill switch next quarter

🔴 Not contained in time 🟡 Detected, human-speed response 🟢 Contained automatically or prevented *Typical starting point; confirmed in week 1

For the board

1. Attackers now use AI to move in minutes. We're making our response automatic for attacks we can identify with near certainty.
2. Automation only touches low-risk systems, is reversible in one click, and every action is logged.
3. By day 90, 9 attack types are contained in seconds, proven by a live simulation.

Guardrails

- 2 weeks recommend-only before any rule acts
- Critical systems and accounts: human only
- Rate limits and circuit breaker stop runaway automation
- AI agent acts only after ≥ 95% agreement with analysts

Asks

Sign containment policy	**Day 30**
Mandate phishing-resistant MFA for admins	**Day 1**
Edge admin pages off the internet	**Day 30**
15 min per app owner for server sign-off	**Day 60**

Day 90 targets

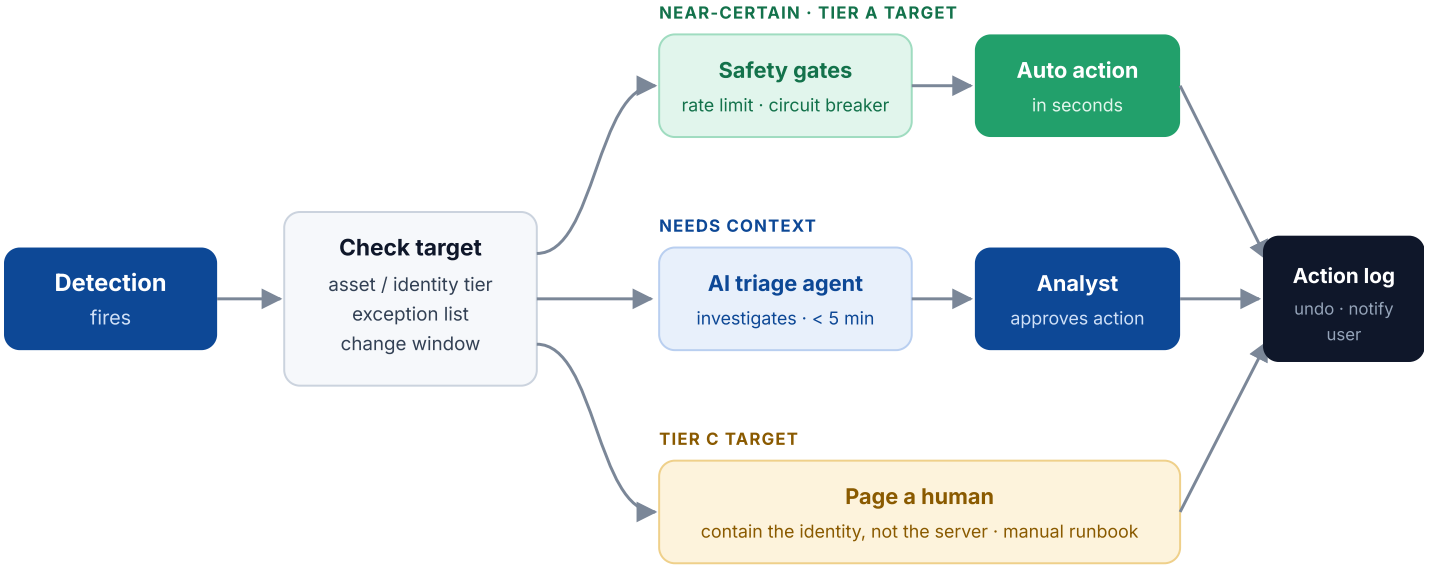
Detect → contain (simulation)	**< 5 min**
Attack types auto-contained	**9**
EDR in block mode	**> 95%**
Admins on phishing-resistant MFA	**100%**

No new tooling assumed: existing EDR, SIEM, identity provider and automation platform. Out of scope this quarter: AI agent kill switch, phishing automation, SaaS and data-theft detection, threat hunting.

ENGINEERING

How it works

Every alert takes one of three paths



Tier A: auto

`workstations · standard users · human cloud roles`

Tier B: contain-lite

`servers (default) · execs · IT admins · workload roles → kill process, block, sign out, page`

Tier C: human only

`DCs · hypervisors · IdP · backup · security tools · break-glass · root`

90-day timeline



ENGINEERING

To-do by phase

→ pointers are IDs in catalog/capabilities.yaml or files in the framework repo

Days 1–30 · authorize and see

effort ~15 pts

- [ ] Draft containment policy wk 1, signed by day 30 → F-01
- [ ] Tag all workstations tier A in EDR; servers default B → checklists/asset-containment-tiers.md
- [ ] Tier C exclusion group: break-glass, service, sync, cloud admin, automation roles → F-03
- [ ] Action log searchable by user/host; user notice on action → F-12
- [ ] Must-have logs flowing, < 5 min lag, silence alert per source → checklists/critical-log-sources.md
- [ ] Exposure inventory + 72 h KEV patch SLA → F-09
- [ ] Edge admin pages off internet; VPN via SSO + MFA → checklists/edge-devices.md
- [ ] Deploy decoys + canary AD user/SPN (recommend-only) → A-01, A-02
- [ ] Start admin phishing-resistant MFA rollout → H-01
- [ ] Run Blind Spot Detector daily (read-only) → agents/blind-spot-detector

Exit: policy signed · workstations tagged · action log live · blind spot report delivered

Days 31–60 · build actions, learn noise

effort ~22 pts

- [ ] Action safety: tier check, undo + bulk undo, rate limits → P1 → F-04
- [ ] Build + test: isolate host, kill process, network block → ACT-01, ACT-10, ACT-07
- [ ] Build + test: revoke sessions, disable account, reset password + MFA → ACT-03, ACT-04, ACT-05
- [ ] EDR > 95% coverage, block mode, anti-tamper, exclusions reviewed → F-05
- [ ] Decoys + canaries → auto (mass-hit breaker on) → A-01, A-02
- [ ] Recommend-only: credential theft, MFA fatigue, recon burst, ransomware prep → A-03, A-06, A-13, A-15
- [ ] Triage agent on EDR high/crit, risky sign-in, new MFA, server shell → agents/triage
- [ ] Alert Tuner drafts narrow exceptions → agents/alert-tuner
- [ ] Server tiers: owner sign-off (no answer = B) → agents/data-steward

Exit: all six actions run + undone on test targets · decoys automatic · every high alert has an agent write-up

Days 61–90 · cloud, edge, go automatic

effort ~21 pts

- [ ] Cloud: revoke creds (tier-aware) + auto-restore logging → ACT-06, ACT-12
- [ ] Cloud detections: logging off, creds outside provider, new privilege / root use → A-08, A-12, D-06
- [ ] Edge admin + config changes → triage → D-12
- [ ] EDR tamper + second signal; circuit breaker tested → A-04
- [ ] AI agent inventory (write/execute agents) → F-10
- [ ] Graduation review → passing rules auto on tier A → agents/alert-tuner/graduation-review
- [ ] Admin MFA at 100% → H-01
- [ ] Simulation: decoy, cred theft, recon, MFA burst, trail disable → F-08

Exit: 9 detections automatic · detect-to-contain measured · scorecard delivered

ENGINEERING

Detections, actions, thresholds

Detection → response

DETECTION	RESPONSE	DAY 90
Decoy / canary touched	isolate · sign out	AUTO
Canary AD account used	isolate source	AUTO
Credential theft	isolate · sign out · reset · block C2	AUTO
MFA fatigue → approve	sign out · remove new MFA · reset	AUTO
Recon burst (≥ N cmds / 60 s)	isolate workstation · sign out	AUTO
Ransomware prep	isolate · disable · block	AUTO
Cloud logging disabled	restore logging · revoke cloud creds	AUTO
Cloud creds used outside provider	revoke cloud sessions · page	AUTO
EDR tamper + 2nd signal	sign out · isolate · page	AUTO*
EDR tamper alone	triage decides	RECOMMEND
EDR high / critical	triage	RECOMMEND
Risky sign-in	triage · sign out / reset	RECOMMEND
New MFA method / help-desk reset	triage · remove method	RECOMMEND
Server spawns shell	triage · isolate / kill	RECOMMEND
New privilege, root / break-glass use	triage · revert	RECOMMEND
Edge admin / config change	triage · disable admin · block IP	RECOMMEND
Prompt injection in evidence	human + research decide	HUMAN

`AUTO = tier A only · *if it passes graduation · trigger logic and required logs → catalog/capabilities.yaml`

Cloud: action by identity type

People

revoke sessions · deactivate key · deny-all

`all automatic`

Workloads

revoke sessions

`auto: workload gets fresh creds, attacker's copy dies · keys/deny-all: recommend`

Root · break-glass · org admin

`page only · logging restore always runs`

Thresholds to configure

Recommend period: ≥ 2 weeks per rule

Rule graduation: ≤ 1 FP / month, fired once, policy-listed

Agent graduation: 30 cases · ≥ 95% agree · 0 harmful · injection test

Rate limits: per rule + per action type → stop + P1

EDR circuit breaker: > 2% sensors silent / hour → no auto

Decoy breaker: > 3 hosts / 15 min → one incident

Decoy reads counted: shells, scripts, editors, archivers, AI agents

Missing tier: host or identity → B

Exceptions: narrowest match · owner · ≤ 12 months

Containment target: structured entities only, never free text